12/10/26

* Case Study-2

Securing the University Examination System

A university uses an Operating System-based examination management system to store student records, examination marks, faculty details, and question papers. The system has three main user groups: Students, Faculty, and Administrators. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student07 has three failed login attempts.
- At 10:03, Student07 successfully logs in.
- At 10:04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks.xlsx by Student07.
- At 10:15, Faculty02 modifies marks in ExamMarks.xlsx and saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity, and availability, prevent unauthorized access, maintain accountability, and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration, and auditing measures

Questions:

Q1] Identify the main security problems in the case study. (4 marks)
List atleast four risks or weaknesses indicated by the scenario.

Q2] Explain the difference between authentication and authorization using Student07 as an example. (4 marks)
Distinguish identity verification from permission checking.

Q3] Recommend an access-control policy for Students, Faculty and Administrators. Justify your choice. (5 marks).

Q4] Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx (5 marks)

Q5] Explain how the Principle of Least Privilege should be applied in this system. (4 marks)

Q6] Interpret the audit events from 10:00 to 10:05. What should the security team do next? (5 marks)

Q7] Identify at least five events that should be recorded

in the audit logs. (3 marks)

Q8] Explain why the audit logs must be protected and recommend two ways to protect them. (3 marks)

Q9] What action should be taken regarding the former faculty member's active account? Explain. (3 marks)

Q10] Suggest a practical incident-response and corrective-action plan for the university. (4 marks)

Ans1] The main system problems in the above case study is the poor access control ove the files. 4 risk of weaknesses are:
- Poor Access Control
- Poor Account Management
- Poor Security
- Insecure Audit log storage.

Ans2]

Authentication	Authorisation
It is used to check whether the user is legit/real or not. In other words check its identity.	It gives the permission or privilege to the user on what he/she is allowed to do with that file.

The login process of 3 failed attempt to access the file and then successful login comes in this comes process.
Identity verification is the "who" of the OS, whereas

permission checking is the "what" of the OS.

Ans 3] The most suitable Access control policy is Role-Based Access Control (RBAC). as it's purpose is to do give permission according to the role, assigned. therefore, with this students can only read marks. faculty can only write marks but admin can do anything.

Ans 4] The ACL for the above case study is:

User	Modification	Read Permission	Write Permission
Student	Deny	Allow	Denied
Faculty	Deny	Allow	Allow
Admin	Allow	Allow	Allow

Ans 5] Principle of least privilege (PoLP) is a rule that states the users and program should only have the minimum access necessary to complete their specific tasks.

User	Required Permissions	Unnecessary Permission
Student	View Only	Write, modify access
Faculty	View, write	Manage, modify system permission
Admin	Manage, modify, alter, etc.	—

Ans 6] The event that starts at 10:00 where there were 3 failed login and one after successful login can not be consider as suspicious as it might be a human error but after that when it escalated to modify the marksheet should trigger the warning as the work done should not be done by student. The immediate steps team of security should take are:

- Suspend or freeze the student or off account
- Terminate all active sessions.
- Contact the actual student about it.
- Examine network.

Ans 7] The 5 security event that must be recorded are:

- Authentication Events (successful or failed logins)
- File and Data Access Events (Read, modify, delete, etc.)
- Account creation, modification or deletion.
- Changes made to roles.
- Changes made with security.

Ans 8] Audit logs purpose is to save history for everything that happens inside the computer system. It should be protected because:

- It will prevent attackers cover-ups
- Ensure there is no repudiation.
- Can help to identify when, where the attack occur from.

It can be protected by:
- Storing the log in a place other than that sit
- Encrypting the logs by hashing or signing it.

Ans9] The active account of the ex-faculty member must be immediately disable and systematically deprovisioned. As keeping it open will violate th rules of principle of least privilege. The ghost account also creates a security hazard.

Ans10] The plan for the university to fix their proble is:

1. Investigate the student's & teacher's activity.
2. Block the former faculty account and lockdown the file.
3. Make new policy with it consultant.
4. Set-up alerts and do periodical checks.